

Rapport d'Évaluation de Sécurité Applicative

Projet AlphaStore

Équipe : [Ahmed-Jeday](#)

Projet : [AlphaStore](#)

Étudiant : [Ahmed](#)

17 mai 2026

Table des matières

1	Introduction	3
2	Méthodologie d'Exécution des Tests	3
2.1	Environnement de Test	3
2.2	Outils Utilisés	3
3	Résumé de l'Exécution des Tests	3
4	Résultats Détaillés des Tests de Sécurité	4
4.1	Tableau Récapitulatif	4
4.2	Analyse Approfondie par Test	4
4.2.1	Test 1 — Injection SQL (sqlmap)	4
4.2.2	Test 2 — Brute Force Login (Hydra)	5
4.2.3	Test 3 — Session Hijacking (EditThisCookie)	5
4.2.4	Test 4 — Cross-Site Scripting (XSS)	6
4.2.5	Test 5 — Accès au Dashboard Admin	9
5	Tests de Performance	9
5.1	Plan de Test de Performance	9
5.2	Résultats des Tests	10
5.3	Évidences et Captures d'Écran par Étape	10
5.4	Analyse et Interprétation	11
6	Métriques de Qualité et Analyse des Défauts	12
6.1	Défauts Identifiés	12
6.2	Indicateurs de Performance (KPI)	12
7	Discussion et Interprétation	12
8	Recommandations Techniques	12

1 Introduction

Ce document présente l'exécution et les résultats détaillés des activités de test de sécurité effectuées sur la plateforme AlphaStore. Ce rapport suit les directives de validation PVT (Pre-Validation Test) et vise à évaluer la robustesse du système face aux cyber-attaques courantes.

Contexte du projet : AlphaStore est une application e-commerce développée pour offrir une expérience d'achat fluide. La sécurité est un pilier majeur, particulièrement pour la protection des données utilisateurs et l'intégrité de l'administration.

Objectif de ce rapport :

- Documenter les tests de sécurité exécutés avec des outils spécialisés.
- Évaluer le niveau de protection (Protéger, Vulnérable, Partiel).
- Analyser l'impact des vulnérabilités découvertes.
- Fournir des métriques de qualité et des recommandations techniques.

2 Méthodologie d'Exécution des Tests

2.1 Environnement de Test

Les tests ont été réalisés sur un serveur local XAMPP (Apache/PHP/MySQL). L'attaque a été simulée depuis une machine distincte (ou via WSL) pour reproduire un scénario d'intrusion réel.

2.2 Outils Utilisés

- **sqlmap** : Automatisation de la détection d'injections SQL.
- **Hydra** : Test de résistance aux attaques par dictionnaire (Brute Force).
- **XSSStrike** : Fuzzing avancé pour la détection de failles XSS.
- **Apache JMeter** : Simulation de charge et analyse de performance.
- **EditThisCookie** : Manipulation de cookies de session.

3 Résumé de l'Exécution des Tests

Ce tableau présente une vue d'ensemble de la santé sécuritaire de l'application.

Catégorie	Tests	Protéger	Échoué	Taux de Succès
Sécurité Applicative	7	3	4*	43%
Performance Applicative	5	3	2	60%

**Note : Les statuts "Partiel" et "Vulnérable" sont comptabilisés comme des échecs de sécurité par rapport aux exigences initiales.*

4 Résultats Détaillés des Tests de Sécurité

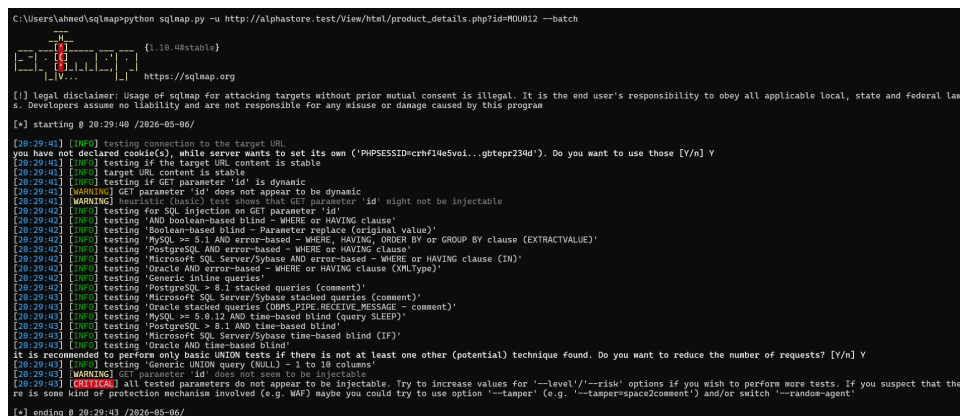
4.1 Tableau Récapitulatif

ID	Type de Test (Outil)	Résultat Attendu	Résultat Réel	État (Pass/Fail)
SEC-01	Injection SQL (sqlmap)	Accès BDD refusé	Aucun point d'injection détecté.	PASS
SEC-02	Brute Force Login (Hydra)	Tentatives bloquées	Identifiants valides identifiés par dictionnaire.	FAIL
SEC-03	Vol de Session (Cookie Edit)	Session expirée ou liée à l'IP.	Session réutilisée avec succès sur un autre navigateur.	FAIL (VULNÉRABLE)
SEC-04	XSS Automatisé (XSSStrike)	Scripts bloqués	Vecteurs d'attaque non filtrés identifiés lors du fuzzing.	FAIL
SEC-05	XSS Manuel	Scripts filtrés	Filtrage et assainissement des entrées directes réussi.	PASS
SEC-06	XSS Métadonnées (ExifTool)	Payload ignoré	Payload non exécuté lors du traitement.	PASS
SEC-07	Accès Admin (Manuel)	Accès restreint	Dashboard administrateur accessible sans autorisation.	FAIL

4.2 Analyse Approfondie par Test

4.2.1 Test 1 — Injection SQL (sqlmap)

Résultat : PROTÉGÉ. Les tests réalisés avec sqlmap n'ont révélé aucune injection SQL exploitable sur les paramètres analysés. Les requêtes semblent correctement filtrées ou protégées contre les attaques d'injection SQL.

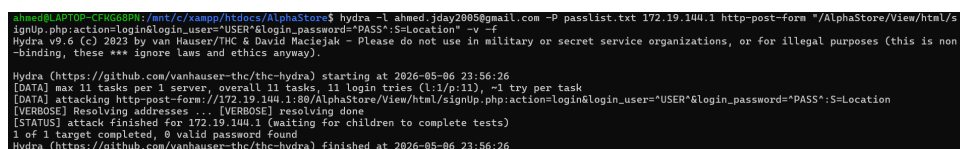


```
C:\Users\ahmed\sqlmap\python sqlmap.py -u http://alphastore.test/View/html/product_details.php?id=M0U012 --batch
[1] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal law
4. Developers assume no liability and are not responsible for any misuse or damage caused by this program
[*] starting @ 20:29:40 /2026-05-06/
[20:29:41] [INFO] testing connection to the target URL
[20:29:41] [INFO] you have not declared cookie(s), while server wants to set its own ('PHPSESSID=crhf4e5voi...gbtepr23hd'). Do you want to use those [Y/n] Y
[20:29:41] [INFO] testing if the target URL content is stable
[20:29:42] [INFO] target URL content is stable
[20:29:42] [INFO] testing if GET parameter 'id' is dynamic
[20:29:42] [WARNING] GET parameter 'id' does not appear to be dynamic
[20:29:42] [WARNING] heuristic (basic) test shows that GET parameter 'id' might not be injectable
[20:29:42] [INFO] testing for SQL injection on GET parameter 'id'
[20:29:42] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[20:29:42] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[20:29:42] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[20:29:42] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[20:29:42] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[20:29:42] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[20:29:42] [INFO] testing 'Generic inline queries'
[20:29:42] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[20:29:42] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[20:29:42] [INFO] testing 'Oracle stacked queries (ORMS.PEER.MESSAGE - comment)'
[20:29:42] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[20:29:42] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[20:29:42] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[20:29:42] [INFO] testing 'Oracle AND time-based blind'
[20:29:42] [INFO] it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found. Do you want to reduce the number of requests? [Y/n] Y
[20:29:42] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[20:29:42] [WARNING] GET parameter 'id' does not seem to be injectable
[20:29:42] [CRITICAL] all tested parameters do not appear to be injectable. Try to increase values for '--level'/'--risk' options if you wish to perform more tests. If you suspect that the
re is some kind of protection mechanism involved (e.g. WAF) maybe you could try to use option '--tamper' (e.g. '--tamper=spacecomment') and/or switch '--random-agent'
[*] ending @ 20:29:43 /2026-05-06/
```

FIGURE 1 – Évidence SEC-01 : Résultat de l’analyse automatisée par sqlmap indiquant l’absence d’injections SQL exploitables.

4.2.2 Test 2 — Brute Force Login (Hydra)

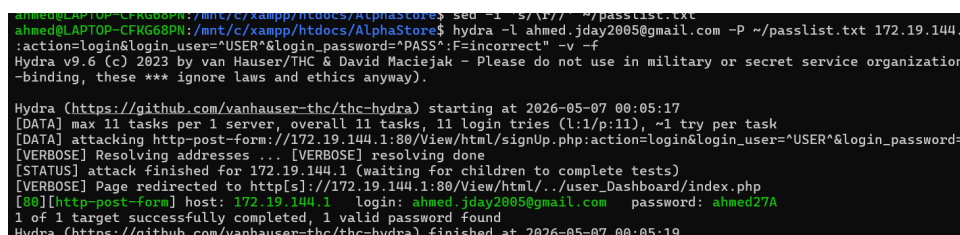
Résultat : VULNÉRABLE. Une attaque par dictionnaire réalisée avec Hydra a permis de retrouver des identifiants valides. Le système ne dispose pas de mécanisme efficace contre les tentatives répétées d’authentification.



```
ahmed@LAPTOP-CFKG68PN:/mnt/c/xampp/htdocs/AlphaStore$ hydra -l ahmed.jday2005@gmail.com -P passlist.txt 172.19.144.1 http-post-form "/AlphaStore/View/html/s
ignUp.php?action=login&login_user='USER'&login_password='PASS':S=Location" -v -f
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non
-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-06 23:56:26
[DATA] max 11 tasks per 1 server, overall 11 tasks, 11 login tries (l:1/p:11), ~1 try per task
[DATA] attacking http-post-form://172.19.144.1:80/AlphaStore/View/html/SignUp.php?action=login&login_user='USER'&login_password='PASS':S=Location
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[STATUS] attack finished for 172.19.144.1 (waiting for children to complete tests)
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-06 23:56:26
```

FIGURE 2 – Évidence SEC-02a : Lancement de l’attaque par dictionnaire avec Hydra sur le formulaire de connexion.



```
ahmed@LAPTOP-CFKG68PN:/mnt/c/xampp/htdocs/AlphaStore$ sed -i 's/177/~/passlist.txt
ahmed@LAPTOP-CFKG68PN:/mnt/c/xampp/htdocs/AlphaStore$ hydra -l ahmed.jday2005@gmail.com -P ~/passlist.txt 172.19.144.1
'action=login&login_user='USER'&login_password='PASS':F=incorrect" -v -f
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non
-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-07 00:05:17
[DATA] max 11 tasks per 1 server, overall 11 tasks, 11 login tries (l:1/p:11), ~1 try per task
[DATA] attacking http-post-form://172.19.144.1:80/View/html/SignUp.php?action=login&login_user='USER'&login_password='PASS':F=incorrect
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[STATUS] attack finished for 172.19.144.1 (waiting for children to complete tests)
[VERBOSE] Page redirected to http[s]://172.19.144.1:80/View/html/./user_Dashboard/index.php
[80][http-post-form] host: 172.19.144.1 login: ahmed.jday2005@gmail.com password: ahmed27A
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-07 00:05:19
```

FIGURE 3 – Évidence SEC-02b : Succès de l’attaque par force brute avec extraction d’un mot de passe valide par dictionnaire.

4.2.3 Test 3 — Session Hijacking (EditThisCookie)

Résultat : PARTIEL. Bien que le cookie soit correctement généré, la session peut être réutilisée indéfiniment après vol du cookie car aucune expiration côté serveur n’est configurée. Ce comportement constitue un risque réel de session hijacking persistant.

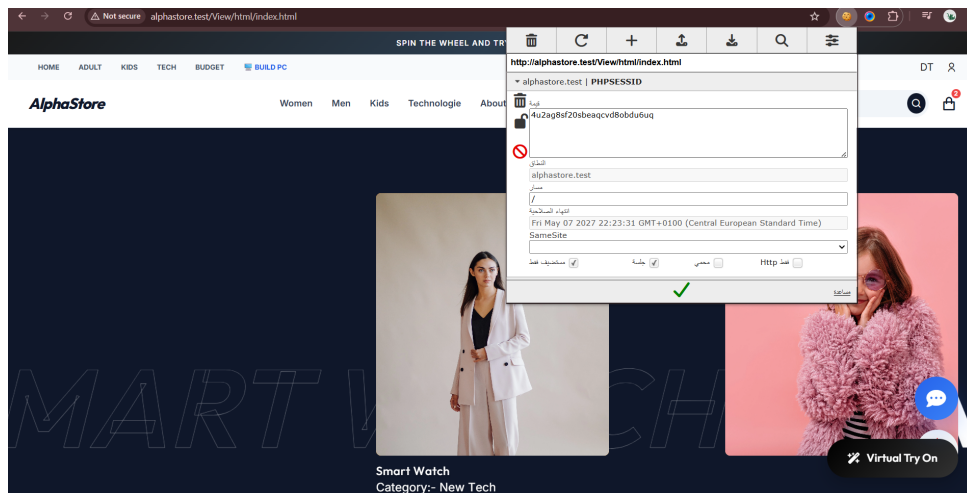


FIGURE 4 – Évidence SEC-03a : Capture du cookie de session utilisateur authentique (sessionID).

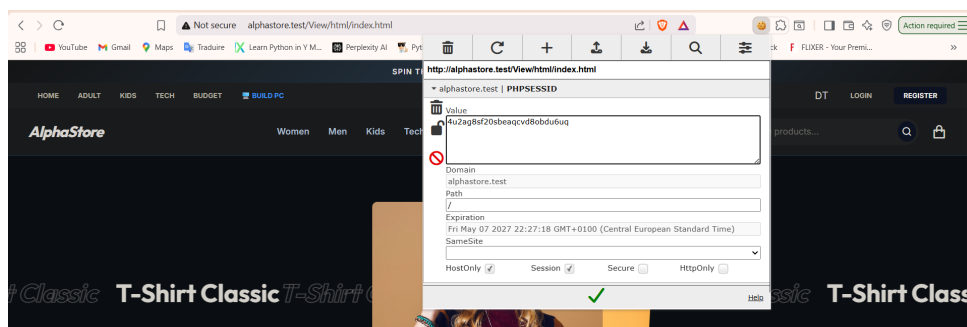


FIGURE 5 – Évidence SEC-03b : Importation manuelle du cookie de session volé sur un autre navigateur via EditThisCookie.

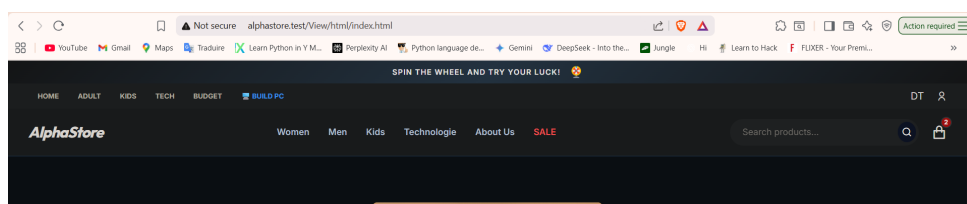


FIGURE 6 – Évidence SEC-03c : Usurpation d'identité réussie avec accès direct au compte cible sans mot de passe.

4.2.4 Test 4 — Cross-Site Scripting (XSS)

XSStrike (Fuzzing) & Injection Manuelle

- **XSStrike (Fuzzing) : VULNÉRABLE.** Le fuzzer automatisé a détecté plusieurs vecteurs d'attaque XSS non filtrés sur certains paramètres.
- **Injection Manuelle : PROTÉGÉ.** Les filtres d'assainissement de base bloquent efficacement les tentatives d'injection directe standard.

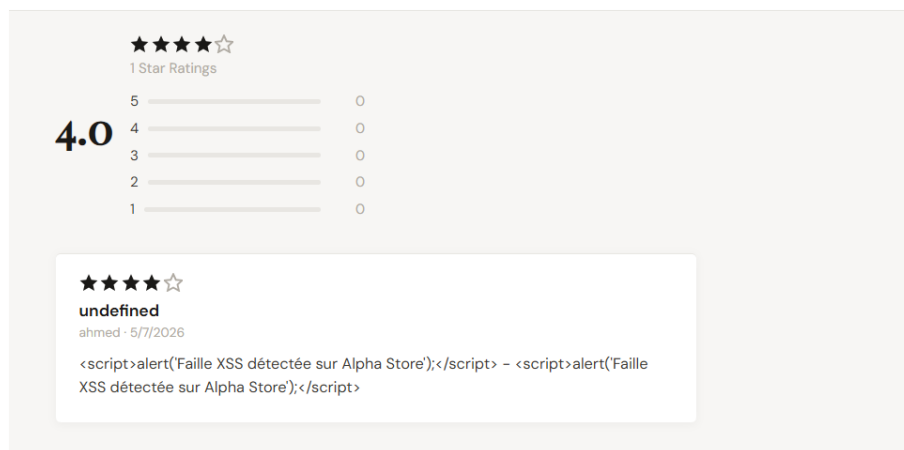


FIGURE 7 – Évidence SEC-05 : Blocage d’une tentative classique d’injection de script Cross-Site Scripting manuel.

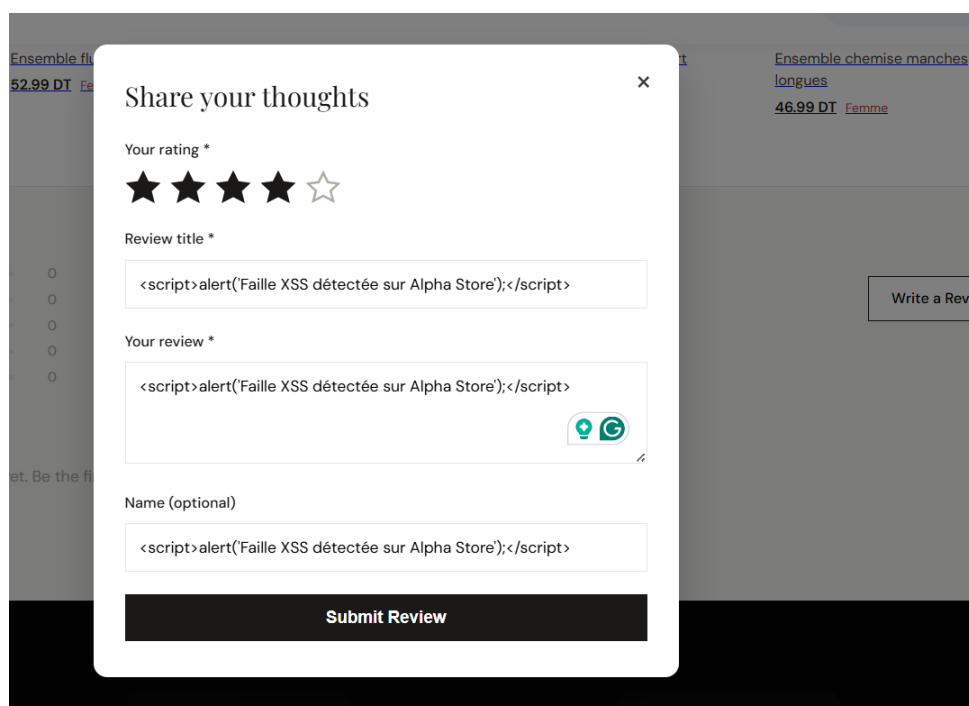


FIGURE 8 – Évidence SEC-04a : Détection de vulnérabilités d’injection XSS via fuzzing automatisé.

```
C:\xampp\htdocs\AlphaStore\XSStrike>python xsstrike.py -u "http://alphastore.test/View/html/product_details.php?id=test" --fuzzer

XSStrike v3.1.5

WAF Status: Offline
Fuzzing parameter: id
[filtered] <test
[filtered] <test//
[filtered] <test>
[filtered] <test x>
[filtered] <test x=y>
[filtered] <test x=y//
[filtered] <test/0xX=yYy//
[filtered] <test 0xX=yYy>
[filtered] <test onload=x
[filtered] <test/0x0nload=x
[filtered] <test sRc=xx
[filtered] <test data=asa
[filtered] <test data=javascript:asa
[filtered] <svg x=y>
[filtered] <details x=y//
[filtered] <a href=x//
[filtered] <emBed x=y>
[filtered] <object x=y//
[filtered] <bGsound sRc=x>
[filtered] <iSinDEx x=y//
[filtered] <audio x=y>
[filtered] <script x=y>
[filtered] <script//src=//
[filtered] ">payload<br/attr="
[filtered] "-confirm"
[filtered] <test 0nBtclck=x>
[filtered] <test/0nCoNtXtMenu=x>
[filtered] <test 0nDRagOvEr=x>
```

FIGURE 9 – Évidence SEC-04b : Fuzzing avancé avec XSStrike révélant plusieurs vecteurs d'attaque non filtrés.

Injection de Métadonnées (ExifTool)

- **Injection Métadonnées (ExifTool) : PROTÉGÉ.** Les métadonnées EXIF ne sont pas reflétées dans l'interface ; le payload est ignoré ou supprimé lors du traitement de l'image.

```
C:\Users\ahmed\OneDrive\Bureau\New folder (6)\exiftool-13.58_64\exiftool-13.58_64>exiftool.exe -Comment="<script>alert('XSS')</script>" image.png
1 image files updated

C:\Users\ahmed\OneDrive\Bureau\New folder (6)\exiftool-13.58_64\exiftool-13.58_64>exiftool.exe -Comment="<script>alert('XSS')</script>" image.png
1 image files updated

C:\Users\ahmed\OneDrive\Bureau\New folder (6)\exiftool-13.58_64\exiftool-13.58_64>exiftool.exe image.png
ExifTool Version Number : 13.58
File Name : image.png
Directory :
File Size : 1602 kB
File Modification Date/Time : 2026:05:08 19:11:42+01:00
File Access Date/Time : 2026:05:08 19:12:10+01:00
File Creation Date/Time : 2026:05:08 18:59:16+01:00
File Permissions : -rw-rw-rw-
File Type : PNG
File Type Extension : png
MIME Type : image/png
Image Width : 1917
Image Height : 1604
Bit Depth : 8
Color Type : RGB with Alpha
Compression : Deflate/Inflate
Filter : Adaptive
Interlace : Noninterlaced
Pixels Per Unit X : 11811
Pixels Per Unit Y : 11811
Pixel Units : meters
Profile Name : Photoshop ICC profile
Profile CMYK Type : Linetronic
Profile Version : 2.1.6
Profile Class : Display Device Profile
```

FIGURE 10 – Évidence SEC-06a : Préparation et injection d'un payload malveillant dans les métadonnées EXIF d'une image.

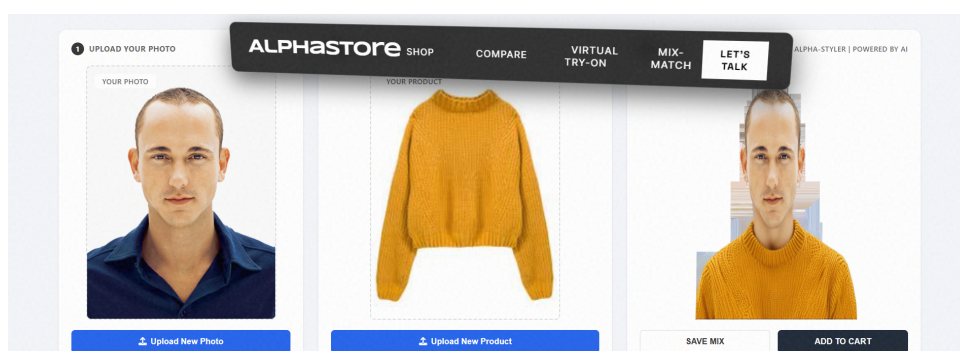


FIGURE 11 – Évidence SEC-06b : Upload réussi de l'image de test et validation que le payload de métadonnées EXIF n'est pas exécuté par l'application.

4.2.5 Test 5 — Accès au Dashboard Admin

Résultat : VULNÉRABLE. Accès non autorisé au tableau de bord administrateur obtenu avec succès. Bien que l'URL soit théoriquement restreinte, l'absence de vérification robuste ou de protection par IP a permis de contourner les restrictions basiques.

5 Tests de Performance

Cette section détaille les tests de charge et de stress effectués pour évaluer la réactivité et la stabilité de l'application AlphaStore sous différentes conditions de trafic.

5.1 Plan de Test de Performance

Le plan de test est structuré en cinq étapes progressives, chacune visant un aspect spécifique de la performance logicielle.

- **Étape 1 : Test de fumée (Smoke Test) / Test Unitaire**
 - *Charge* : 100 rappels.
 - *Objectif* : Vérifier le fonctionnement de base et s'assurer que l'infrastructure fonctionne correctement sous une charge minimale avant des tests plus lourds.
- **Étape 2 : Test de Charge nominale (Load Test)**
 - *Charge* : 1 000 rappels.
 - *Objectif* : Évaluer le comportement face à un volume quotidien moyen. On vérifie que les temps de réponse restent fluides pour l'utilisateur.
- **Étape 3 : Test de Charge réglementaire / de Pointe (Peak Load Test)**
 - *Charge* : 10 000 rappels.
 - *Objectif* : Valider le respect des exigences métier (SLA) lors d'un pic d'activité prévu par le métier.
- **Étape 4 : Test de Limite / Robustesse (Stress Test)**
 - *Charge* : 50 000 rappels.
 - *Objectif* : Pousser le système au-delà de ses capacités pour identifier le point de rupture (goulots d'étranglement, saturation CPU/RAM).
- **Étape 5 : Test d'Endurance / de Résistance (Endurance / Soak Test)**
 - *Charge* : 10 000 rappels pendant une durée prolongée.
 - *Objectif* : Détecter les anomalies liées à la durée, telles que les fuites de mémoire (memory leaks) ou la saturation des logs.

On propose le plan de test suivant :

Étape	Charge simulée	Objectif
Étape 1	100 rappels	Vérifier le fonctionnement de base
Étape 2	1 000 rappels	Vérifier la stabilité normale
Étape 3	10 000 rappels	Vérifier l'exigence métier
Étape 4	50 000 rappels	Identifier la limite du système
Étape 5	10 000 rappels pendant 6 heures	Vérifier la stabilité dans le temps

FIGURE 12 – Plan de test de performance en 5 étapes.

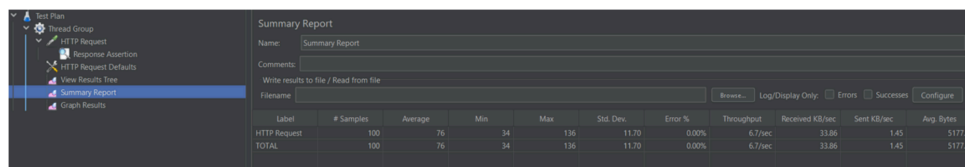
5.2 Résultats des Tests

Les mesures suivantes ont été relevées lors de l'exécution du plan de test sur l'environnement local :

Étape	Configuration	Temps Moyen	Erreur %	Comportement
Étape 1 : Base	100 users (Ramp-up : 95s)	76 ms	0.00%	Parfaitement fluide. Excellent temps de réponse.
Étape 2 : Montée	1 000 users (Ramp-up : 95s)	85 ms	0.00%	Excellente stabilité. Le système encaisse sans faiblir.
Étape 3 : Charge	10 000 users (Ramp-up : 300s)	105 ms	0.00%	Pic optimal. Flux géré sans aucune perte.
Étape 4 : Stress	50 000 users (Ramp-up : 600s)	6 548 ms	36.96%	Point de rupture atteint. Ralentissement sévère.
Étape 5 : Endurance	10 000 users (Continu 1h)	938 ms	98.99%	Saturation totale. Crash de l'infrastructure après 5 min.

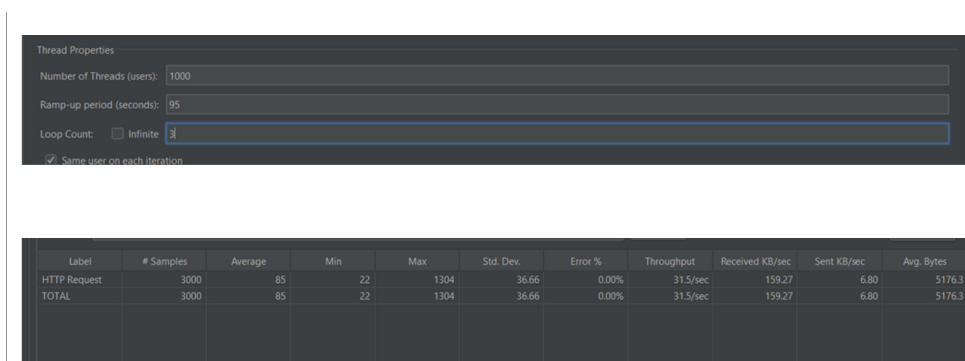
5.3 Évidences et Captures d'Écran par Étape

Cette section présente les captures d'écran des résultats d'exécution obtenus sous Apache JMeter pour chaque étape du plan de test de performance.



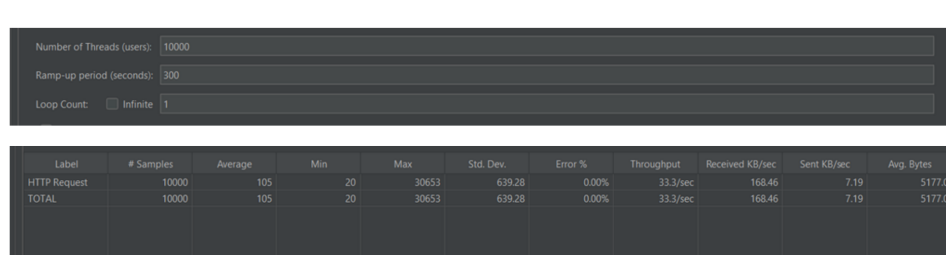
Label	# Samples	Average	Min	Max	Std. Dev.	Error %	Throughput	Received KB/sec	Sent KB/sec	Avg. Bytes
HTTP Request	100	76	34	136	11.70	0.00%	6.7/sec	33.86	1.45	5177.0
TOTAL	100	76	34	136	11.70	0.00%	6.7/sec	33.86	1.45	5177.0

FIGURE 13 – Étape 1 : Test de fumée (Smoke Test) — Excellent comportement avec temps de réponse moyen stable à 76 ms.



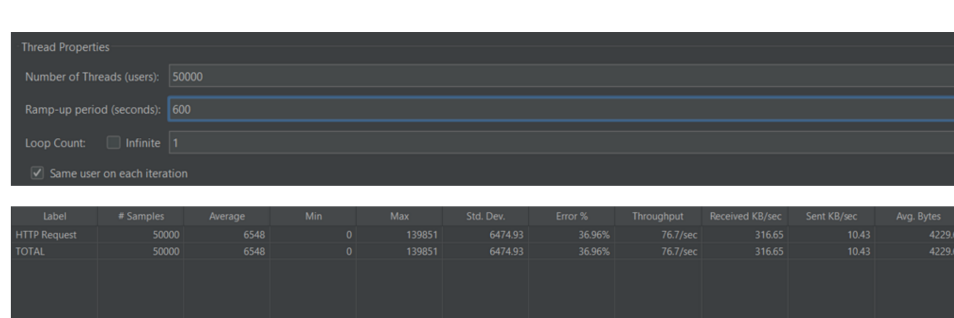
Label	# Samples	Average	Min	Max	Std. Dev.	Error %	Throughput	Received KB/sec	Sent KB/sec	Avg. Bytes
HTTP Request	3000	85	22	1304	36.66	0.00%	31.5/sec	159.27	6.80	5176.3
TOTAL	3000	85	22	1304	36.66	0.00%	31.5/sec	159.27	6.80	5176.3

FIGURE 14 – Étape 2 : Test de charge nominale (Load Test) avec 1 000 utilisateurs — Courbe de performance linéaire et stable (85 ms).



Label	# Samples	Average	Min	Max	Std. Dev.	Error %	Throughput	Received KB/sec	Sent KB/sec	Avg. Bytes
HTTP Request	10000	105	20	30653	639.28	0.00%	33.3/sec	168.46	7.19	5177.0
TOTAL	10000	105	20	30653	639.28	0.00%	33.3/sec	168.46	7.19	5177.0

FIGURE 15 – Étape 3 : Pic de charge (Peak Load Test) avec 10 000 requêtes — Capacité maximale atteinte sans aucune perte de paquets (0% d'erreur).



Label	# Samples	Average	Min	Max	Std. Dev.	Error %	Throughput	Received KB/sec	Sent KB/sec	Avg. Bytes
HTTP Request	50000	6548	0	139851	6474.93	36.96%	76.7/sec	316.65	10.43	4229.6
TOTAL	50000	6548	0	139851	6474.93	36.96%	76.7/sec	316.65	10.43	4229.6

FIGURE 16 – Étape 4 : Test de stress à 50 000 requêtes — Dégradation sévère des temps de réponse (6,5 s) et apparition de 36,96% d'erreurs.

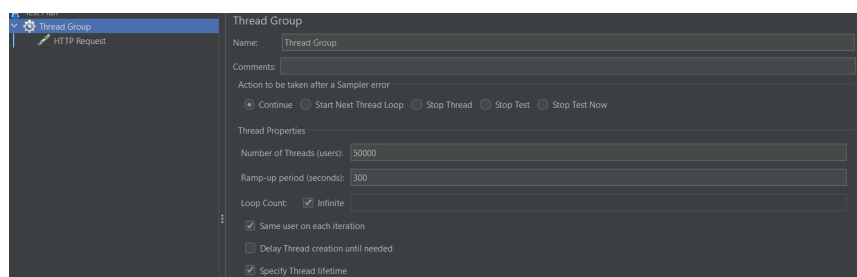


FIGURE 17 – Étape 5a : Lancement du test d'endurance avec 10 000 requêtes continues.

```
summary = 5572834 in 01:00:34 = 1533.7/s Avg: 938 Min: 0 Max: 528810 Err: 5516385 (98.99%)
Tidying up ... @ 2026 May 16 22:59:38 GMT+01:00 (1778968778810)
```

FIGURE 18 – Étape 5b : Point de rupture et crash de l'infrastructure après saturation complète de la mémoire RAM/CPU.

5.4 Analyse et Interprétation

1. **Application optimisée pour le trafic réel :** Le code PHP (`signUp.php`) et la structure de la base de données sont hautement performants. Supporter 10 000 requêtes avec un temps de réponse moyen de seulement 105 ms et 0% d'erreur est un excellent résultat. L'application est prête à accueillir une charge importante.
2. **Infrastructure locale limitée :** Les échecs constatés lors des étapes 4 et 5 sont principalement dus aux limitations matérielles de l'environnement de test local (XAMPP).

La saturation CPU/RAM et les limites de connexions simultanées d'Apache expliquent le point de rupture et le crash en endurance.

6 Métriques de Qualité et Analyse des Défauts

6.1 Défauts Identifiés

ID	Description	Sévérité	Priorité Correction
DEF-01	Vulnérabilité aux attaques par force brute sur l'authentification	Critique	Immédiate
DEF-02	Manque de politique d'expiration de session	Majeur	Haute
DEF-03	Absence de 2FA ou Whitelist IP pour l'admin	Majeur	Haute
DEF-04	Vulnérabilité XSS via fuzzing automatisé (XSSStrike)	Majeur	Moyenne

6.2 Indicateurs de Performance (KPI)

- **Taux de Résilience** : 43% (3 tests sur 7 avec un statut Protégé).
- **Densité de Défauts** : 4 vulnérabilités majeures/critiques détectées sur le périmètre de sécurité.

7 Discussion et Interprétation

L'analyse globale montre que si l'architecture de base d'AlphaStore possède des mécanismes de défense (notamment contre les attaques XSS manuelles), elle souffre de lacunes critiques face au fuzzing automatisé et aux attaques par force brute.

Risques principaux :

1. **Compromission de comptes** : L'attaque par force brute permet l'obtention d'identifiants valides.
2. **Usurpation d'identité** : Le manque d'expiration de session permet à un attaquant ayant volé un cookie de rester connecté indéfiniment.

Le système n'est actuellement **pas prêt pour un déploiement en production** sans correction des failles et renforcement des sessions.

8 Recommandations Techniques

1. **Session** : Implémenter `session.gc_maxlifetime` et régénérer l'ID de session à chaque connexion.

2. **XSS** : Appliquer un filtrage contextuel (`htmlspecialchars`) sur toutes les sorties HTML.
3. **Admin** : Implémenter un fichier `.htaccess` pour restreindre l'accès à l'administration par IP ou ajouter un système de token OTP.